Caso real de ingeniería social: ataque a Twitter (15 de julio de 2020)

Ficha elaborada con fines educativos a partir de fuentes públicas oficiales.

Qué ocurrió

El 15 de julio de 2020, cuentas de Twitter de políticos, celebridades, empresarios y empresas de criptomonedas publicaron mensajes del tipo "duplica tus bitcoins" con una dirección para enviar pagos.

Cómo entraron los atacantes

Llamaron por teléfono a empleados de Twitter haciéndose pasar por personal del departamento de TI (vishing o phishing telefónico). Convencieron a cuatro empleados de entregar sus credenciales de acceso y, con ellas, usaron herramientas internas para tomar el control de cuentas de alto perfil.

Impacto

Los atacantes obtuvieron más de 118,000 dólares en bitcoins de usuarios que creyeron los mensajes. Empresas de criptomonedas reguladas bloquearon con rapidez transferencias adicionales a las direcciones de los atacantes.

Hallazgos de la investigación oficial (NYDFS)

Al momento del ataque, la empresa no tenía un director de seguridad de la información (CISO), ni controles adecuados de acceso, gestión de identidades y monitoreo de seguridad.

Fuentes

New York State Department of Financial Services, comunicado del 14 de octubre de 2020: https://www.dfs.ny.gov/reports_and_publications/press_releases/pr202010141

CISA, Avoiding Social Engineering and Phishing Attacks: https://www.cisa.gov/news-events/news/avoiding-social-engineering-and-phishing-attacks